



File No.: EXP202201000 (PS/00626/2022)

-

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on January 12, 2022. The complaint is directed against the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA with NIF S4611001A (hereinafter, the respondent). The reasons on which the complaint is based are as follows:

The claimant states that there have been unauthorized accesses to their medical history by four coworkers, one of whom is their immediate supervisor. They have informed the data controller and have not received a response.

Along with the notification, a representation letter is submitted, a request for data on unauthorized access addressed to the IT Unit of the Hospital de la Fe of the Consejería de Sanidad Universal y Salud Pública de la Generalitat Valenciana, a report issued by the Subdirectorate of Information Systems of Hospital La Fe regarding user accesses to part of the evidence from the claimant's Medical History, and finally, a complaint filed with the Sindic de Greuges.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), on February 8, 2022, the complaint was forwarded to the respondent, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations. The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on February 8, 2022, as recorded in the acknowledgment of receipt in the file.

On March 8, 2022, this Agency received a report sent by the Data Protection Officer of the Generalitat Valenciana containing the information stated in Proven Fact Six.

On March 9, 2022, this Agency received a written response to the forwarding of the complaint, to which a series of documents were attached.

THIRD: On April 12, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/26

FOURTH: On May 17, 2022, after analyzing the documentation in the file, a resolution was issued by the Director of the Spanish Agency for Data Protection, agreeing to archive the complaint. The resolution was notified to the complaining party on May 23, 2022, through the Electronic Notification Service and the Authorized Electronic Address according to the certificate in the file.

FIFTH: On June 21, 2022, the complaining party filed a request for reconsideration through the Electronic Registry of this Agency, against the resolution issued in file EXP202201000, by which the complaint was agreed to be archived. Along with the request, new relevant documentation was submitted regarding the matters raised in the complaint, specifically, a series of emails exchanged with the supervisor of ***POSITION.3 in which he informed him of the situation of medical leave (...); this supervisor had accessed the medical history of the complaining party 5 minutes before sending an email requesting information about the results of his tests, so he did not access the information in his medical history for healthcare reasons, but for organizational issues related to work shifts.

On October 11, 2022, the Deputy Director General of Data Inspection agreed to forward the request filed by the complaining party to the CONSELLERÍA, granting him the opportunity to present

allegations and submit the documents and justifications he deems appropriate, in accordance with the provisions of Article 118 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.

The aforementioned opportunity to present allegations was notified on October 13, 2022, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations. On October 27, 2022, the responding party submitted a written statement of allegations that has been incorporated into the file.

SIXTH: On November 17, 2022, the Director of the Spanish Agency for Data Protection issued a resolution on the request for reconsideration, by which the request filed by the complaining party was upheld and it was agreed to admit the complaint for processing in accordance with the provisions of Article 65 of the LOPDGGDD.

SEVENTH: On February 24, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the responding party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, as well as for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR.

EIGHTH: The aforementioned initiation agreement was notified to the responding party on February 27, 2023, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

3/26

LPACAP), the responding party submitted a written statement of allegations with the following content: "FIRST. Lack of notification of the resolution by which the appeal filed by the claimant is upheld.

The resolution by which the appeal for reconsideration filed by the claimant has been upheld has not been notified to this Ministry or to the Data Protection Delegation of the Generalitat Valenciana. This situation creates a state of defenselessness as this party became aware of the outcome of the appeal through the notification of the Agreement to initiate sanctioning proceedings.

Furthermore, these circumstances have prevented this Ministry from filing the corresponding appeal against the aforementioned Resolution, and we are equally unaware of the reasons and the grounds on which the arguments put forth by the claimant are upheld, thus limiting this party's right to defense.

SECOND.- In the opinion of the Local Safety Committee of Hospital La Fe, the claimed facts do not constitute a security breach, considering that in the Clinical History of the Community of Valencia there are sufficient physical controls to prevent access by unauthorized personnel to healthcare assistance, and to the computer workstations where the clinical history is consulted (which requires user identification and password). In this regard, the Committee expresses itself in its report sent to the Spanish Agency for Data Protection dated February 8, 2022, and similarly responded to the claimant through a written document (outgoing register 07/UFE/2021/21865 dated March 7, 2022) which is included as Annex 4 of the aforementioned Committee report.

Therefore, access to clinical histories is restricted and limited. Only healthcare personnel in the exercise of their functions are authorized to access patients' health data, as established by internal protocols and emphasized in the training activities offered to hospital staff.

THIRD.- The hospital believes that it has acted diligently in the protection of patients' data and that the action protocols and training activities are adequate. The Ministry has already informed the AEPD about these aspects in the response to the request made, in the report sent to the Spanish Agency for Data Protection dated February 8, 2022, prepared by the Committee, which resulted in the filing of the proceedings.

However, both the hospital and the Ministry are committed to the continuous improvement of their procedures, seeking to guarantee the protection of the rights of patients and citizens in the best possible way. One of these actions is the review of the identification procedures for personnel and the traceability of their actions.

FOURTH.- For all the above reasons, reiterating what was indicated in the allegations presented in the previous writings and assuming the commitment to act within a dynamic of continuous improvement,

we request the filing of the proceedings as we understand that the facts referred to in the complaint do not warrant a sanction.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/26

NINTH: On September 27, 2023, a resolution proposal was made, proposing that the Director of the AEPD sanction the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, with NIF S4611001A:

- For an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, with a warning.

- For an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a warning.

This resolution proposal, which was notified to the accused in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on September 27, 2023, as evidenced by the acknowledgment of receipt in the file.

TENTH: On October 11, 2023, a written response from the accused was received by this Agency, in due time and form, in which they presented allegations to the resolution proposal, summarizing that the Conselleria de Sanidad establishes and applies security controls to safeguard the confidentiality and integrity of personal data. Furthermore, access to the clinical history is restricted and limited. Only healthcare personnel in the exercise of their functions are authorized to access patients' health data, as established by internal protocols and emphasized in the training activities offered to hospital staff. Finally, it is alleged that the hospital applies sufficient technical and organizational measures to preserve the security and privacy of its information systems.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: On April 29, 2021, the complainant submitted a complaint to the Síndic de Greuges of the Comunitat Valenciana with the following content:

“I am a nurse in the Clinical Neurophysiology Service of the University and Polytechnic Hospital of La Fe (Valencia). I have reasonable suspicions that several people from my Service have accessed my Health Clinical History without my consent. For this reason, I requested the access history from the hospital's SAIP, receiving it only with the date and time, the position held by the person accessing it, and the service to which they belong, but at no time was I provided with their name and surname. Without knowing the identity of the individuals who accessed my information without my authorization, I cannot file the pertinent complaint with the AEPD. How is it possible that such a serious act is defended by protecting the offender above the rights of the affected party? How can the Síndic de Greuges help me gather this information? I look forward to your response shortly and attach the SAIP report.”

SECOND: On June 15, 2021, the complainant again addressed the Síndic de Greuges of the Comunitat Valenciana, with the following message:

“I filed a complaint with you on 04/29/2021, which you accepted for processing under file number ***REFERENCE.1.

Since more than a month has passed since it was processed, I would like to know the status of the request for the names of those who accessed my history and what the Conselleria has responded, or inform me if they will not provide them, what organizations I should approach; since another of my colleagues was provided with this information after requesting it.”

THIRD: On June 29, 2021, the Conselleria de Sanitat Universal i Salut Pública sent the following message to the Síndic de Greuges of the Comunitat Valenciana:

“Mr. Síndic:

In response to your request for information regarding the indicated complaint and its outgoing

registration ***REFERENCE.2, dated 03/05/2021, and reiterated on 06/16/2021, we attach the report from the Subdirectorate of Information Systems of the Management of the Health Department of València-La Fe, with the information requested by the complainant.

This letter serves as a response to the notification received.

We thus comply with the provisions of Article 19.1 of Law 11/1988, of December 26, on the Síndic de Greuges and the obligations undertaken by public administrations."

FOURTH: On June 7, 2021, the Subdirectorate of Information Systems of the Management of the Health Department of València-La Fe issued a report in response to the request made on May 3, 2021, by the Síndic de Greuges of the Comunitat Valenciana, in order to respond to the complaint filed by the complainant. In this report, sent on June 29, 2021, from the Conselleria de Sanitat Universal i Salut Pública to the Síndic de Greuges of the Comunitat Valenciana, the following is stated:

"In response to your request, this Subdirectorate of Information Systems of Hospital La Fe sends you the 'report of the computer movements to date of the clinical history ***REFERENCE.3', in order to comply with what was requested by Ms. A.A.A.

Having consulted the database where the information on user access to part of the tests of the patient's Clinical History is stored, it has been obtained that the users who have accessed the clinical information available at Hospital La Fe for Clinical History number ***REFERENCE.3 are detailed below:

Accesses to the clinical history ***REFERENCE.3 of specialized (ordered chronologically from most to least recent):

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/26

Date and Time

Position

Service

Name and Surname

28/01/2021 10:42

***POSITION.1

PNEUMOLOGY AND PEDIATRIC ALLERGY

[CEX]

B.B.B.

28/01/2021 10:28

***POSITION.2

NURSING UNIT E50

C.C.C.

[...]

15/07/2020 10:04

***POSITION.3

NEUROPHYSIOLOGY

D.D.D.

[...]

01/06/2020 13:37

***POSITION.3

NEUROPHYSIOLOGY

E.E.E.

FIFTH: On September 24, 2021, the claimant submitted a written document addressed to the data controller of the Health Department-La Fe, with the following content:

"Through the Subdirectorate of Information Systems (written document dated June 7, 2021) and following a request from the Ombudsman, the undersigned has become aware of a series of unlawful intrusions into her medical record no. 643698 carried out by Ms. E.E.E. on June 1, 2020, on July 15,

2020, by Ms. D.D.D., and on January 28, 2021, by Ms. B.B.B. and Mr. C.C.C.

Since they were not authorized to consult her medical record at any time by the undersigned, I understand that there has been an unjustified intrusion into my medical record, which makes it necessary for the data controller to justify the reason for such illegal access, in case there is any security breach in the processing of the data.

For all of this,

I request that the data controller justify this illegal access to my medical record and investigate whether there has been any breach in the security of said data processing."

SIXTH: On March 8, 2023, in response to the transfer of the complaint to the defendant party made by this Agency, the Data Protection Officer of the Generalitat Valenciana sent a report to this Agency prepared by the Management Directorate of the Health Department Hospital La Fe-Valencia of the Ministry of Universal Health and Public Health, stating that:

"BACKGROUND

Ms. A.A.A. had submitted a written document on September 24, 2021, addressed to the data controller requesting clarification on whether there was any unauthorized access to her Medical Record, and that the fact be justified by the data controller, and that it be determined whether the access constituted a security breach.

Ms. A.A.A. provided a report of accesses provided by the Subdirectorate of Systems of this Hospital, where it is confirmed that the user of the corresponding computer workstation for the individuals mentioned in the complaint accessed her medical record on the indicated days.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/26

Subsequently, on January 12, 2022, the interested party directed a complaint to the Spanish Agency for Data Protection, motivating her complaint by not having received a response from the data controller regarding the clarifications requested due to alleged unauthorized accesses to her Medical Record.

Of the four individuals cited in the Complaint, one, B.B.B., according to the information from the Directorate ***POSITION.1, is not listed in the personnel register as anyone with that name who has performed functions typical of the staff dependent on this Directorate.

The remaining individuals investigated are healthcare personnel in this Hospital, and their job position requires access to the electronic Medical Record of all patients, with the authorizations and functional restrictions established by the regulations in this regard.

Healthcare personnel practice their profession in accordance with their Deontological code, the knowledge of which is foundational to their training and is an accepted ethical self-regulation norm that inspires and guides their conduct.

The Hospital informs its employees, through various means, that accesses to the Medical Record of personnel providing services in the Hospital must be carried out strictly in the exercise of the functions of the position they occupy. Any other access must be considered unauthorized access.

RESPONSE TO THE REQUEST OF THE SPANISH AGENCY FOR DATA PROTECTION.

Decision made regarding this complaint.

In response to the first request of the complainant (dated 24/09/21), the matter was addressed in a meeting of the Local Committee for Information Security on October 6, 2021, recorded in the minutes that, "in response to the request for a study of a security breach, a response is drafted clarifying that there was none and outlining the technical and organizational security measures applied in the hospital and the inquiries that confirm this."

The Hospital acknowledges that, although the matter was addressed in the Local Committee for Information Security in a reasonable time, at the time the complaint was presented by the interested party to the Agency, the response had not yet been sent, as it was pending while other matters were

attended to. However, the response is already in progress according to documentation provided later. From the Directorate ***POSITION.1, inquiries have been initiated with the three hospital employees who hold the user accounts that the affected party claims are the authors of the unauthorized accesses; namely, Ms. E.E.E., Ms. D.D.D., and Mr. C.C.C.

The responses obtained from them are attached (Annexes 1, 2, and 3). It is noted that from the supplied list, there is one name that does not correspond to any person in this Hospital.

It should be stated in this regard, without prejudice to the results of the investigation initiated regarding the unauthorized accesses to the record of Ms. A.A.A., that the aforementioned Committee understands that there was no security breach, considering the fact that in the..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/26

Clinical History of the Valencian Community there are sufficient physical controls to prevent access by unauthorized personnel to healthcare assistance, or with malicious intentions, to the computer workstations that consult the Electronic Clinical History.

In view of the access records, we confirm that they were made by healthcare personnel who have access authorization in the exercise of their functions, and no evidence has been found of any impact on the integrity or availability of the Electronic Clinical History subject to the complaint.

Accreditation of the response provided to the complainant.

A document with the registered outgoing response (Annex 4) is attached, in which the complaining party is informed that unauthorized accesses are being investigated, and that there is no security risk beyond the thresholds accepted by the Ministry of Universal Health and Public Health, therefore the Local Information Security Committee does not classify the complaint as a security breach.

Causes that have motivated the incident that originated the complaint.

The main cause of this incident is the access that healthcare personnel have to the Electronic Clinical History of the patient in public hospitals of the Valencian Community.

This universal access to the Electronic Clinical History is granted to all healthcare professionals hired in the health system of the Valencian Community in the exercise of their functions, based on the criterion of prioritizing the general interest of preserving individual health, through the ubiquitous treatment of any clinical episode of a citizen of the Valencian Community in the healthcare centers managed by the Ministry of Universal Health and Public Health, and by any formally accredited professional.

Measures adopted to prevent similar incidents

The technical and organizational measures that guarantee security in access to the Electronic Clinical History of the Valencian Community, as well as the functional rules of the applications that manage said history, are defined by the Ministry of Universal Health and Public Health, in accordance with its assigned competencies.

Access to the Electronic Clinical History is restricted to healthcare professionals based on their role in the system, through the application of technical and organizational measures in accordance with RD 3/2010 which regulates the National Security Scheme. Any other person outside the healthcare provision does not have access to the information systems that make up the Electronic Clinical History.

The Health Department is particularly aware of its responsibility for the custody of its patients' data, and has been applying these measures for some time.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/26

However, it cannot be denied that legitimately authorized professionals to access the Electronic

Clinical History may, at some point, due to ignorance, error, or bad faith, incur in unauthorized access to a patient's Electronic Clinical History.

To prevent a legitimately authorized professional from incurring unauthorized access, the Ministry of Universal Health and Public Health focuses on training, information, and awareness of its personnel. These measures are applied to achieve full training, awareness, and information of the professionals in this Department:

- 1- At the time of delivery and signing of the employment contract, the signing of an annex with information related to the protection of the data they will access in the performance of their functions is included.
- 2- Various links have been deployed on the security portal of the department's intranet with information intended for this training purpose.
- 3- The Access Request Form to the Hospital Information Systems includes a page dedicated to the regulations for the use of the systems, and the duty of confidentiality in accessing information in the exercise of their functions. A document is attached (Annex 5).
- 4- The Hospital schedules specific annual Communication Plans for each group. An example of an annual session for new resident doctors is attached. (Annex 6)
- 5- The Ministry of Universal Health and Public Health includes in its Continuing Education plans ongoing Training and Self-Training in Data Protection.

Measures aligned with the National Security Scheme (ENS)

The Security Policies and access rules to the information systems of the Valencian Generalitat also apply to the Ministry of Universal Health and Public Health and to this Health Department, and are respectively included in the DECRETO 66/2012 of the Consell, which establishes the information security policy of the Valencian Generalitat,

(https://dogv.gva.es/portal/ficha_disposicion.jsp?sig=004163/2012&L=1)

and in the ORDER 19/2013, of December 3, of the Ministry of Finance and Public Administration, which establishes the rules on the safe use of technological means in the Administration of the Generalitat.

(https://dogv.gva.es/datos/2013/12/10/pdf/2013_11767.pdf).

Based on these regulations, this Department has defined its security policy accessible on the public web

<http://www.lafe.san.gva.es/documents/18/d9239b5c-0a27-4b4e-a3618fe2d778d3b6>.

The Regulations for the use of the Information Systems of the Health Department are also included in a specific document sufficiently disseminated on its security portal, accessible from the Hospital's intranet. A document with the rules is attached (Annex 7).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/26

In the event that unauthorized access to a medical record by Hospital staff is confirmed, it would lead to the initiation of a preliminary investigation that could result in the proposal of a disciplinary file."

SEVENTH: On March 9, 2023, a document was received in this Agency from the Data Protection Delegation of the Generalitat Valenciana, which includes the following documentation:

1- Allegations D.D.D., stating the following:

"[...] I did not access the medical record of the complainant at any time on 15/07/2020 at 10:04 AM, as I have been informed. As a work practice, and given the short time I had been working in the service, since my incorporation was on 23/03/2020 during the COVID pandemic, where I was quickly transferred to another service to assist, during the dates indicated in the complaint, there were many things for which I consulted doubts about records and appointments on the computers, clinical sessions were left open in various parts of the neurophysiology service as a usual practice, so anyone could have accessed from my clinical session, adding that I had barely had any interaction in the service due to the short time I had been there." (the emphasis is ours).

2- Allegations E.E.E., stating the following:

"[...] In this part, it is considered relevant that (...) we had started the session on the computer, and we frequently had to attend to the requirements of the service, at the request of both patients and doctors, being this situation responsible for the fact that during that time, the computers were left unattended and with the sessions open, allowing other colleagues to use the computer without closing the session and starting a new one, continuing with the same user that was active at that moment, a fact that is a usual practice and whose purpose was to achieve greater optimization of the available resources." (the emphasis is ours).

3- Allegations C.C.C.

"[...] It is a usual practice to open one or several clinical sessions during the workday, which due to the work dynamics may occasionally be left unattended, which is why, upon suspicion that someone might use my session fraudulently, I requested on March 22, 2021, that the IT service automatically block my session after five minutes of inactivity." (the emphasis is ours).

4- Response Letter from Complainant A.A.A.

Sent on March 7, 2023, from the Directorate of ***POSITION.3 of the Health Department of Hospital de la Fe, a response (page 157 of the file) is sent to the complaint filed by the complainant, the terms of which are recorded in Proven Fact Five. In this response, it is stated that:

"Regarding the allegations of the appellant, the issue was discussed in a meeting of the Local Committee on Information Security on October 6, 2021, and it is recorded in the minutes that, 'in response to the request to study a security breach, a response was drafted clarifying that there was none and outlining the technical and organizational security measures applied in the hospital and the inquiries that confirm this...'"

5- Template for Access Requests to Systems. This is a Request Form for Access to the Hospital's Information Systems, which includes a page dedicated to the regulations for the use of the systems and the duty of confidentiality in accessing information in the performance of their functions.

6- Awareness Course. A series of images of the content of a training session that, according to the respondent, is provided to new resident doctors are attached.

7- Rules for the Use of Systems.

This document states the following:

"1. OBJECTIVE

The objective of this document is to establish the rules for the use of the computer assigned to the work position of the staff of the VALENCIA-LA FE HEALTH DEPARTMENT, the corporate network, portable equipment, software applications, as well as regarding access to and processing of personal data, in electronic format and on paper.

It is essential that all employees of the VALENCIA LA FE HEALTH DEPARTMENT who use computer equipment and access or process critical and personal information for the performance of their functions and tasks are aware of this rule.

2. SCOPE

This document applies to all activities of the VALENCIA - LA FE HEALTH DEPARTMENT in the area of obtaining, processing, and transferring personal data and in the processing of essential information. This document is mandatory for all personnel of the VALENCIA - LA FE HEALTH DEPARTMENT or external personnel who have access to personal data processed by the VALENCIA - LA FE HEALTH DEPARTMENT and to essential information, and will be located in the corresponding shared directory, internally, and will be sent to external personnel via email.

These security rules apply to the protected resources available to the VALENCIA - LA FE HEALTH DEPARTMENT, as well as to all third parties that process data on behalf of the VALENCIA - LA FE HEALTH DEPARTMENT.

[...]

4. DEVELOPMENT

[...]

Users must comply with the following security measures for the use of personal computers:

[...]

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/26

- Portable devices and other computer media are made available solely and exclusively for the purpose of enabling the performance of assigned functions and tasks, and their use for any other personal purposes is prohibited.
- The access passwords to the equipment, system, and/or network, granted by the DEPARTMENT OF HEALTH VALENCIA - LA FE, are personal and non-transferable, with the User being the only responsible party for any consequences that may arise from their misuse, disclosure, or loss. Thus, it is prohibited, among other things: i) to use identifiers and passwords of other Users to access the system and network of DEPARTMENT OF HEALTH VALENCIA - LA FE, ii) to attempt to modify or access the access log, iii) to circumvent the security measures established in the computer system by attempting to access files, and iv) in general, the use of the corporate network, systems, computer equipment, and any means made available to the User, violating the rights of third parties, those of this Organization, or for the performance of acts that could be considered illegal.

[...]

In relation to the above, access to the files or documents owned by this Organization, provided solely for the functions or tasks performed at DEPARTMENT OF HEALTH VALENCIA - LA FE, must be restricted to third parties (family members, friends, or any others). Additional protective measures will be established to ensure the confidentiality of the information stored on the equipment when the User requests it or when it concerns personal data that requires the security measures established by current legislation.”

EIGHTH: Upon the submission of a request for reconsideration against the dismissal of their claim, the claiming party presents a series of emails, with the following details:

1.- Dated January 21, 2021, at 15:50 hours, an email was sent from ***EMAIL.1 with the subject “***SUBJECT.1” to the following recipients: ***EMAIL.2; ***EMAIL.3; ***EMAIL.4. The message sent is transcribed as follows:

“Informing that the result of my son’s PCR has been positive. I have already informed occupational risks so that they can give me the guidelines to follow. Sincerely, best regards A.A.A.”

2.- From the email ***EMAIL.1, the following message was sent:

“The result of the PCR performed on the 25th has been negative; I am awaiting the result of the PCR that they will perform on me on the 27th for discharge. Sincerely, A.A.A.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/26

3.- Dated January 28, 2021, at 10:33, an email was sent from ***EMAIL.3 with the subject “***SUBJECT.2” to the following recipients: ***EMAIL.2; ***EMAIL.5; ***EMAIL.4. The message sent is transcribed as follows:

“Did they do the PCR on you yesterday??? How did it turn out??? Have they given you discharge??? Will you work tomorrow, Friday the 28th???”

4.- Dated January 28, 2021, at 10:46 hours, an email was sent from ***EMAIL.1 with the subject “***SUBJECT.1” to the following recipients: ***EMAIL.2 and ***EMAIL.3. The message sent is transcribed as follows:

“They just called me from sprl that the result is negative, so I will have the discharge dated today A.A.A.”

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Response to the allegations made against the initiation agreement and to the allegations made against the proposed resolution

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/26

A) In relation to the allegations made regarding the initiation agreement of the present sanctioning procedure, a response is provided according to the order presented by the responding party in their writing:

"FIRST. Lack of notification of the resolution by which the acceptance of the appeal filed by the claimant is agreed."

The responding party has had the opportunity to present allegations regarding the reasons that led to the acceptance of the appeal once the initiation agreement was notified, in which a period was granted to present allegations, which are addressed in this document, therefore no defenselessness has occurred.

Regarding the lack of knowledge alleged by the responding party about "the reasons and the basis for which the arguments presented by the claimant are accepted," the resolution of the appeal was incorporated into the file, so, in accordance with the provisions of Article 53.1.a) of the LPACAP, they have the right to access and obtain a copy of said resolution of the appeal.

For all the above reasons, this allegation is dismissed.

"SECOND. In the opinion of the Local Safety Committee of Hospital La Fe, the alleged facts do not constitute a security breach."

According to the responding party, "there are sufficient physical controls to prevent access by unauthorized personnel to healthcare assistance, and to the computer workstations where the medical history is consulted (requires user identification and password) ... Therefore, access to medical histories is restricted and limited. Only healthcare personnel in the exercise of their functions are authorized to access patients' health data."

However, in the "report of the computer movements to date of the medical history ***REFERENCE.3" issued by the Subdirector of Information Systems of the Management of the Health Department of València-La Fe, reproduced in Proven Fact Four, it is noted that a consultation was made on 28/01/2021 at 10:28, by the position "supervisor of ***POSITION.3" C.C.C., who five minutes later, at 10:33 on the same day, asked by email (Proven Fact Eight, email 3) the claimant whether they had been discharged and if they were going to work that same day. In a previous email, the claimant had informed this supervisor that they were pending a PCR to be performed on January 27 to know if they would be discharged. Even on 28/01/2021 at 10:42 hours, subsequent to the aforementioned events, access to the Claimant's Medical History was made by B.B.B., of whom the responding party states that, as recorded in Proven Fact Six, "there is no record of any person with that name who has performed functions typical of the personnel dependent on this Directorate." Furthermore, in the report of the medical history ***REFERENCE.3, there are two accesses recorded from dates prior to those previously mentioned that would also not be authorized, as they are not linked to any treatment received by the claimant in the HEALTH DEPARTMENT OF VALENCIA – LA FE.

For all these reasons, on one hand, the undue access of personnel from the HEALTH DEPARTMENT

VALENCIA - LA FE to the Claimant's Medical History is evidenced, without these accesses being linked to any type of treatment that

15/26

the claimant was receiving at the DEPARTMENT OF HEALTH VALENCIA - LA FE, and on the other hand, the access to the Clinical History of the claimant by a third party not affiliated with the aforementioned organization, who is not listed as an employee of the service in question.

For all the above, this allegation is dismissed.

“THIRD.- The hospital considers that it has acted diligently in the protection of patient data and that the action protocols and training activities are adequate.”

In response to this allegation, it should be noted that, both from the facts subject to this procedure and from the documentation sent by the Data Protection Delegation of the Generalitat Valenciana, the lack of appropriate technical and organizational measures to ensure a level of security adequate to the risk to prevent unauthorized access to the Electronic Clinical History of patients of the Valencian health service has been demonstrated. Furthermore, in the testimony of the individuals who unjustifiably accessed the Clinical History of the claimant, it is stated that it is common practice for sessions on computers to remain open and unattended (Proven Fact Seventh, documents 1, 2, and 3). In document 7 of Proven Fact Seventh “Usage Policy of the Systems,” which establishes the usage rules for the computer assigned to the workplace of the staff of the DEPARTMENT OF HEALTH VALENCIA - LA FE, the corporate network, portable devices, and software applications, it is stated that “The access passwords to the equipment, system, and/or network, granted by the DEPARTMENT OF HEALTH VALENCIA - LA FE, are personal and non-transferable... Thus, it is prohibited, among others: i) to use identifiers and passwords of other Users to access the system and the network of the DEPARTMENT OF HEALTH VALENCIA - LA FE.” However, the fact that the sessions of the Clinical History consultation application can remain open without automatic session locking due to user inactivity may allow unauthorized consultations of the Clinical History by other users. In one of the statements submitted by the defendant, one of the employees of the DEPARTMENT OF HEALTH VALENCIA - LA FE requests the IT service for a measure such as automatic session locking after five minutes of inactivity (Proven Fact Seventh, document 3).

Moreover, consultations of a patient's Clinical History must be linked to a treatment or medical consultation. For example, access to the Clinical History is considered unauthorized when the reason for such access is to know the result of a medical test to determine if a colleague will come to work. It cannot be stated, as the Local Committee on Information Security did in the response sent to the claimant (document 4 of Proven Fact Seventh), that there was no security breach and that the technical and organizational measures applied in the hospital and the investigations confirm this, as it is precisely the opposite.

The CONSELLERÍA states that “Only healthcare personnel in the exercise of their functions are authorized to access patients' health data, as established by internal protocols and emphasized in the training activities offered to hospital staff,” to which it can be responded that the security breach also...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/26

It occurs when the healthcare personnel dependent on the CONSELLERÍA, even if they are internal staff, makes an unauthorized access to patient data, which constitutes a violation of the provisions of Article 32 of the GDPR.

On the other hand, in response to the transfer of the complaint made by this Agency, the CONSELLERÍA indicates that the measures adopted “focus on the training, information, and awareness of its personnel. Therefore, no specific technical or organizational measures have been justified to prevent unauthorized access to the Electronic Medical Record of individuals who are not even being attended to by the Valencian health service; no analysis of the errors that have occurred and the specific measures that could prevent them has been conducted.

For all the above, this allegation is dismissed.

B) Regarding the allegations made against the proposed resolution of this sanctioning procedure, a response is provided according to the order presented by the CONSELLERÍA DE SANIDAD:

“FIRST. - Regarding the qualification of the facts that constitute a violation of Article 5.1.f) of the GDPR, with a proposal for a warning sanction:”

In this allegation, the respondent argues that, in previous procedures opened by this Agency for unauthorized access to clinical information, the suitability and sufficiency of such controls have not been questioned.

What the respondent refers to as “previous procedures” are merely referral actions provided for in Article 65.4 of the LOPDGDD, for the purpose of determining the admission or inadmissibility of the complaint, so it is not any type of previous procedure that has established any type of precedent. Furthermore, the resolution of archiving referred to by the respondent was revoked by a resolution accepting the appeal filed by the complainant, as explained in Background Sixth, due to the fact that, from the documentation provided by the complainant, indications of unauthorized accesses, not justified to their electronic medical record, could be appreciated. In the resolution of the appeal, the admission of the complaint for processing was declared, leading to the initiation of the present procedure.

For all the above, this allegation is dismissed.

“SECOND. Regarding the qualification of the facts that constitute a violation of Article 32 of the GDPR related to the security of processing:”

In these allegations, the respondent lists a series of technical and organizational measures to preserve the security and privacy of its information systems.

Specifically, a measure for controlling the reason for access to the medical records is included in the response forwarded by Hospital La Fe – Valencia to C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/26

MINISTRY, which states that “In relation to the risk of unauthorized access to information, we specify evidence that supports the controls applied to prevent it:

[...]

8- There is a consultation screen for Medical Histories, a window prior to access containing a notice and recording the reason provided by the user. Evidence #8 is provided.”

By applying this control measure, the respondent should be able to justify the reason for the accesses to the Electronic Medical History of the claimant. However, the reason put forth by the respondent for the accesses that are the subject of the complaint is as follows: “...However, during the COVID pandemic, it is possible that specific extraordinary actions were taken regarding the organization of shifts and the organization of staff to facilitate patient care given the increase in absences among healthcare personnel who were also victims of the pandemic.”

Well, this argument contradicts the statements made by three individuals who improperly accessed the personal data of the claimant, partially reproduced in Proven Fact Seven.

In the document “1.- Allegations D.D.D.” it is stated “... I did not access the medical history of the complainant at any time.” In the document “2- Allegations E.E.E.” in the file, it is declared “that I did not carry out the accesses attributed to me.” Likewise, in the document “3- Allegations C.C.C.” in the file, it is declared “that neither on the date indicated in your writing nor at any other time did I access the medical history of the ***POSITION.1...”.

Consequently, none of the testimonies from the individuals who improperly accessed the claimant's data can justify the respondent's argument that the cause of access was the organization of shifts and staff organization, as the respondent defends in their written allegations.

For all the above reasons, this allegation is dismissed.

“THIRD. - Consequently, we consider that the facts stated in the complaint do not demonstrate inappropriate or negligent behavior on the part of this Ministry that would justify the proposed sanction. Regardless of the above, both the Ministry and the hospital management are committed to the continuous improvement of their procedures, seeking to ensure the best possible protection of the

rights of patients and citizens. In this regard, one of the actions planned as a result of this complaint is the review of the procedures for identifying personnel, controlling access to information, and tracing their actions, as well as the corresponding training reinforcements for personnel with access to sensitive information.”

In response to this allegation, regarding the behavior attributable to the respondent, it is necessary to distinguish between the infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/26

a) Violation of Article 5.1.f) of the GDPR.

From the facts established in this procedure, it is determined that the confidentiality of the personal data of the claimant has been breached by healthcare personnel dependent on the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA by consulting, without any normatively supported reason, the Electronic Medical Record of the claimant, which establishes the administrative responsibility of the aforementioned CONSELLERÍA. In order to confirm the responsibility of the CONSELLERÍA for the actions carried out by its personnel, it is pertinent to bring to attention the Judgment of the Supreme Court No. 188/2022 (Contentious Chamber, Section 3), dated February 15, 2022 (rec. 7359/2020), whose Fourth Legal Basis states: “...As we already stated in the STS No. 196/2020, dated February 15, 2021 (rec. 1916/2020), the data processor is also responsible for the actions of its employees and cannot excuse itself based on its diligent conduct, separately from the actions of its employees, but rather it is the "culpable" actions of these employees, resulting from the violation of existing security measures, that underpins the company's responsibility in the sanctioning realm for "own" acts of its employees or officials, not of third parties.”

b) Violation of Article 32 of the GDPR.

Regarding the facts constituting the violation of Article 32 of the GDPR attributable to the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, although the respondent justifies a series of technical and organizational measures to preserve the security and privacy of its information systems, these measures were not adequate to prevent the events subject to the complaint, thus the violation of Article 32 of the GDPR occurs due to the absence of measures that would have prevented the breach.

For all the above reasons, this allegation is dismissed.

III

Integrity and confidentiality

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in such a manner as to ensure an appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by means of the application of appropriate technical or organizational measures (‘integrity and confidentiality’).”

In this case, it is established that unauthorized access to the medical record of the claimant, contained in the database of the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, has occurred, violating the principle of confidentiality. According to the reports provided by the claimant, four accesses to their medical record were made by healthcare personnel (...) but in no case for healthcare or medical reasons, (...). The access to the medical record occurred for reasons related to the regulation of work shifts, as evidenced by the emails provided by the claimant. On page 1 of the “report of the computer movements to date of the medical record ***REFERENCE.3”, a consultation is recorded on 28/01/2021 at 10:28, by the position “supervisor of ***POSITION.3” C.C.C., who at 10:33 on the same day emailed the claimant asking if they had been discharged and if they were going to work that same day. In a previous email, the claimant had informed this supervisor that they were awaiting a PCR to be performed on January 27 to know if they

would be discharged. On 28/01/2021, following the aforementioned events, unauthorized access occurred again by someone not listed in the personnel registry of HOSPITAL LA FE - VALENCIA, according to the response sent on 08/03/2022 by the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA in response to the transfer of the complaint made by this Agency. Furthermore, the claimant refers to two other accesses reflected in the "report of the computer movements to date of the medical record ***REFERENCE.3" from dates prior to those mentioned above, which would also not be authorized.

At this procedural moment of resolving the sanctioning procedure, there is evidence that Article 5.1.f) of the GDPR has been violated, as unauthorized third parties had access to the personal data of the claimant, thus their confidentiality was not guaranteed.

IV

Classification and qualification of the violation of Article 5.1.f) of the GDPR

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA did not adequately guarantee the confidentiality and integrity of the personal data under its ownership.

The known facts constitute a violation, attributable to the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, classified under Article 83.5 of the GDPR, which stipulates the following:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/26

In this regard, the LOPDGDD, in its article 71 "Infringements" establishes that

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations for infringements, the alleged infringement is subject to a three-year limitation period, in accordance with article 72 of the LOPDGDD, which qualifies the following conduct as very serious:

"1. Based on what is established in article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will be subject to a three-year limitation period, which entail a substantial violation of the articles mentioned therein, and in particular, the following:

a) The processing of personal data violating the principles and guarantees established in article 5 of Regulation (EU) 2016/679. (...)"

V

Sanction for the infringement of article 5.1.f) of the GDPR

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

"Without prejudice to the corrective powers of the supervisory authorities under article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Furthermore, article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which they are responsible or act as processors:

a) ...

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

d) ...

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/26

The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the Official State Gazette or the corresponding autonomous gazette.

4. The resolutions related to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

Therefore, for the aforementioned infringement of article 5.1.f) of the GDPR, it is appropriate to sanction the claimed party with a warning.

VI

Security of processing

Article 32 “Security of processing” of the GDPR establishes:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/26

2. When the responsible parties or data processors listed in section 1 commit any of the violations referred to in articles 72 to 74 of this organic law, the competent data protection authority shall issue a

resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the violation that has been committed.

The resolution shall be notified to the responsible party or data processor, to the body to which they hierarchically report, if applicable, and to the affected parties who have the status of interested parties, if applicable.

3. Without prejudice to the provisions of the previous section, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for doing so. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the violations are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible official and shall order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities. In the present case, as expressed by the party being claimed in their response to the transfer of the complaint made by this Agency, the security breach occurred due to universal access to the Electronic Health Record, which is granted to all healthcare professionals contracted in the health system of the Valencian Community in the exercise of their functions, so there are no appropriate technical or organizational measures that guarantee that unauthorized access by healthcare personnel to the personal data existing in the Electronic Health Record of patients does not occur. In response to the transfer of the complaint made by this Agency, the CONSELLERIA states that the measures adopted "focus on the training, information, and awareness of its staff." Therefore, no specific technical or organizational measures have been justified to prevent unauthorized access to the Electronic Health Record of individuals who are not even being attended to by the Valencian health service; no analysis has been made of the errors that have occurred and the specific measures that could prevent them. In short, the sufficiency of such measures to prevent similar security breaches in the future is not justified.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/26

At this procedural moment of resolving the sanctioning procedure, there is evidence that Article 32 of the GDPR has been violated, due to the lack of appropriate measures based on the risk to prevent unauthorized access.

VII

Classification and qualification of the violation of Article 32 of the GDPR

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA does not have appropriate measures based on the risk to prevent unauthorized access as occurred in this case, taking into account that health-related data is included in Article 9 of the GDPR in the special categories of personal data, whose processing deserves greater protection.

The known facts constitute a violation, attributable to the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, classified in Article 83.4 of the GDPR, which stipulates the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Violations" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute violations."

For the purposes of the statute of limitations for violations, the imputed violation prescribes after two years, in accordance with Article 73.f) of the LOPDGDD, which qualifies the following conduct as serious:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following violations are considered serious and shall prescribe after two years, which involve a substantial breach of the articles mentioned therein and, in particular, the following: (...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

(...)

VIII

Sanction for the violation of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/26

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Likewise, Article 77, "Regime applicable to certain categories of controllers or processors," of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which they are responsible or which they process:

a) ...

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

d) ...

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be taken to cease the conduct or to correct the effects of the infringement that has been committed.

The resolution shall be notified to the controller or processor, to the body to which they are hierarchically dependent, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for the processing that have not been duly addressed is proven, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order the publication in the corresponding Official State or autonomous Bulletin.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the

Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

25/26

Therefore, for the aforementioned infringement of Article 32 of the GDPR, it is appropriate to sanction the requested party with a warning.

IX

Adoption of measures

It is agreed to impose on the responsible party that within a period of 9 months, they proceed to adopt the necessary technical and organizational measures to prevent unauthorized access to the electronic Medical History of users of the health services provided by the CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA DE LA GENERALITAT VALENCIANA, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...". The imposition of this measure is compatible with the sanction consisting of a warning, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to initiate further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA, with NIF S4611001A:

- For an infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, a warning sanction.
- For an infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR, a warning sanction.

SECOND: TO ORDER CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA, with NIF S4611001A, that pursuant to Article 58.2.d) of the GDPR, within a period of 9 months, they prove to have complied with the necessary technical and organizational measures to prevent unauthorized access to the electronic Medical History of users of their health services.

THIRD: TO PROPOSE to CONSELLERIA DE SANIDAD UNIVERSAL Y SALUD PÚBLICA, with NIF S4611001A, pursuant to the provisions of Article 77.3 of the LOPDGDD, the initiation of disciplinary proceedings against the individuals responsible for the unauthorized accesses.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

26/26

FOURTH: NOTIFY this resolution to the MINISTRY OF UNIVERSAL HEALTH AND PUBLIC HEALTH.

FIFTH: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested

parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Court of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-250923

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es